

RansomShield — Aide-mémoire de soutenance

Discours complet — 10 min de présentation + 5 min de démo

Codjo Fréjus Loïc SANGRONIO — 24 juin 2026

À lire au calme avant la soutenance ; en séance, s'en servir comme filet de sécurité, pas comme texte à réciter mot à mot. Le numéro « Diapo N » correspond exactement au numéro affiché dans le panneau de diapositives. Les **flèches vertes** sont des phrases à prononcer pour enchaîner vers la diapo suivante.

Diapo 1/22 — OUVERTURE

Excellence Monsieur le Président du jury, Mesdames et Messieurs les membres du jury, bonjour.

Permettez-nous, avant toute chose, de vous exprimer notre profonde reconnaissance pour avoir répondu présents à ce rendez-vous. Ce jour revêt pour nous un cachet tout particulier : il est l'aboutissement de ces années de formation, et un moment qui restera gravé dans notre parcours.

Le sujet ayant fait l'objet de notre étude est intitulé : *Conception et mise en place d'un système de détection et de réponse aux attaques ransomware dans un environnement contrôlé*.

C'est avec fierté et humilité que nous vous présentons aujourd'hui RansomShield — un système conçu et mis en place de bout en bout pour détecter et contrer les attaques ransomware, de manière contrôlée et traçable, avec une validation humaine à chaque étape décisive.

↪ **Voici comment s'articule cette présentation.**

Diapo 2/22 — SOMMAIRE

Excellence Monsieur le Président du jury, Mesdames et Messieurs les membres du jury,

Notre présentation s'articule en cinq parties. Nous partirons du contexte et de la problématique qui ont motivé ce travail, pour aller vers un état des lieux des solutions existantes, puis la conception et la réalisation du système. Nous conclurons par les perspectives et terminerons par une démonstration en conditions réelles.

↪ **Commençons par le contexte et la problématique.**

Diapo 4/22 — CONTEXTE

Nous entrons dans la première partie de notre exposé, consacrée au contexte et aux motivations de ce travail.

Aujourd'hui, les entreprises, les hôpitaux, les universités fonctionnent grâce à leurs données numériques. Le ransomware — c'est-à-dire un logiciel malveillant qui rend les données inaccessibles puis exige une rançon — exploite précisément cette dépendance. En 2023, ces attaques ont progressé de 73 % selon l'ENISA, avec un coût moyen de plus d'un million de dollars par incident. Ce qui est particulièrement grave : sans outil adapté, une attaque passe en moyenne 21 jours sans être détectée. C'est 21 jours pendant lesquels les dommages s'accumulent en silence.

↪ **Ce constat nous amène à la problématique centrale.**

Diapo 5/22 — PROBLÉMATIQUE

Ce contexte nous amène naturellement à la problématique centrale de ce travail.

Le constat est simple : les antivirus fonctionnent par reconnaissance d'empreintes. Ils connaissent les menaces déjà répertoriées. Mais face à une variante inédite d'un ransomware, ils restent complètement aveugles. Et pendant ce temps, les données sont chiffrées, les sauvegardes effacées, les dommages deviennent irréversibles.

Le problème que ce travail cherche à résoudre est le suivant : il n'existe pas de solution libre et démontrable en conditions réelles pour détecter ces attaques à partir de leurs comportements, avec un contrôle humain intégré à chaque étape.

Trois défis ont structuré ce travail : les variantes inconnues que les outils traditionnels ne voient pas, la diversité des systèmes à surveiller, et le risque qu'une réponse automatique sans validation humaine cause elle-même des dommages.

↪ Ces défis ont défini les six objectifs que voici.

Diapo 6/22 — OBJECTIFS

Pour répondre à cette problématique, six objectifs précis ont guidé ce travail.

D'abord, surveiller en temps réel les activités fichiers sur chaque terminal. Ensuite, analyser ces activités pour calculer un niveau de risque. Puis, déclencher automatiquement des alertes dès qu'un comportement suspect est détecté. Le principe fondateur : soumettre chaque action proposée à la décision d'un opérateur humain. L'accès est en outre sécurisé par une double authentification — mot de passe et code temporaire valide 30 secondes. Et pour valider l'ensemble, des scénarios d'attaque représentatifs ont été définis et exécutés.

↪ Voyons maintenant les fondements théoriques de ce travail.

Diapo 8/22 — DÉFINITION & COMPORTEMENTS

Excellence Monsieur le Président du jury, Mesdames et Messieurs les membres du jury,

Nous entrons dans la deuxième partie de notre exposé : la revue de littérature. Permettez-nous de commencer par définir précisément ce qu'est un ransomware.

Un ransomware agit toujours selon le même schéma. Il commence par accéder à vos fichiers, les renomme avec une extension inhabituelle pour les rendre illisibles, dépose une note de rançon, puis efface les sauvegardes automatiques pour rendre toute récupération impossible. Enfin, il utilise parfois des outils légitimes du système pour masquer sa présence et passer inaperçu.

Ce sont ces comportements observables, ces traces laissées sur le système, qui forment la base de notre approche. Si l'on surveille ces actions en temps réel, on peut réagir avant que les dommages soient irréversibles.

↪ Mais pourquoi les outils existants ne suffisent-ils pas ?

Diapo 9/22 — SOLUTIONS EXISTANTES

Face à cette menace bien documentée, des solutions existent. Voyons pourquoi elles restent insuffisantes pour notre contexte.

Les antivirus ne reconnaissent que les menaces déjà cataloguées dans leur base de données. Les SIEM — systèmes de centralisation des journaux d'activité — collectent des informations, mais sans chercher activement des comportements suspects. Les EDR — solutions de surveillance avancée des terminaux — sont très efficaces, mais leur coût les rend inaccessibles pour la grande majorité

des organisations — PME, hôpitaux, administrations, associations — qui n'ont pas les budgets des grands groupes.

RansomShield occupe cet espace laissé vacant : une solution libre, comportementale, déployable sur n'importe quelle infrastructure, avec un contrôle humain intégré à chaque étape — conçue pour les entreprises et organisations qui veulent se protéger sans dépendre de solutions propriétaires coûteuses.

↪ **Voyons maintenant comment ce système a été conçu.**

Diapo 11/22 — ARCHITECTURE

Excellence Monsieur le Président du jury, Mesdames et Messieurs les membres du jury,

Nous entrons dans la troisième partie : l'analyse et la conception de RansomShield. Voici l'architecture générale du système — vous pouvez la lire de gauche à droite.

Un agent, installé sur chaque terminal de l'organisation, observe en permanence toute activité inhabituelle sur les fichiers. Ces observations sont transmises au serveur central, qui les analyse et calcule un score de risque. Dès que ce score dépasse un seuil configuré, une alerte est générée automatiquement et une action de protection est proposée à l'opérateur. C'est lui qui prend la décision finale. Le système n'agit jamais seul : chaque intervention est soumise à une validation humaine.

↪ **Voyons de plus près les quatre composants.**

Diapo 12/22 — LES 4 COMPOSANTS

Voyons maintenant de plus près les quatre composants qui constituent ce système.

L'agent de surveillance, d'abord : installé sur chaque machine, il observe en temps réel toute activité inhabituelle sur les fichiers et conserve ces informations localement, pour ne rien perdre même en cas de coupure réseau.

La console de supervision, ensuite : c'est le poste de commandement, là où l'opérateur suit les alertes, prend ses décisions et consulte l'historique complet de toutes les actions.

Le module de découverte réseau : il signale automatiquement les nouvelles machines, mais aucune n'est intégrée au système sans accord explicite de l'administrateur.

Enfin, le simulateur : il reproduit des scénarios d'attaque réalistes, sans déployer le moindre malware réel — ce qui a permis de valider le système en toute sécurité.

↪ **Qui sont les acteurs qui interagissent avec ce système ?**

Diapo 13/22 — DIAGRAMME USE CASE

Ce diagramme présente les deux profils d'utilisateurs qui interagissent avec RansomShield, et la répartition claire de leurs responsabilités.

L'administrateur configure et pilote le système : il connecte les agents, définit les règles de détection et lance les simulations.

L'analyste SOC — pour Security Operations Center, c'est-à-dire le centre opérationnel de sécurité — traite les incidents au quotidien : il consulte les alertes, approuve ou rejette les actions proposées, et suit l'historique complet des événements.

Cette séparation des rôles est volontaire : l'analyste ne peut pas modifier la configuration, ce qui garantit l'intégrité du système.

→ **Passons maintenant à la réalisation concrète.**

Diapo 15/22 — CHOIX TECHNIQUES

Excellence Monsieur le Président du jury, Mesdames et Messieurs les membres du jury,

Nous voici dans la quatrième partie de notre exposé, consacrée à la réalisation et aux résultats. Commençons par les choix techniques.

Trois critères ont guidé ces choix : fonctionner sur différents systèmes d'exploitation, être facile à installer, et être démontrable en conditions réelles sans infrastructure coûteuse.

Pour le serveur et la console, le choix s'est porté sur Laravel — un cadre de développement web robuste et éprouvé. Pour l'agent de surveillance, Python, qui offre une excellente portabilité sur Windows, Linux et macOS. L'environnement de test repose sur trois machines virtuelles isolées, reproduisant les conditions d'un vrai réseau d'entreprise.

L'accès à la console est protégé par une double authentification : après le mot de passe, l'utilisateur doit saisir un code temporaire valide 30 secondes seulement.

→ **Voyons concrètement comment l'agent et le moteur fonctionnent.**

Diapo 16/22 — AGENT & MOTEUR DE DÉTECTION

Entrons dans le cœur du système : l'agent de surveillance et le moteur de scoring.

Voici comment fonctionne l'agent au quotidien : dès son démarrage, il est reconnu par le serveur central grâce à un jeton sécurisé à usage unique. Il commence alors à surveiller les dossiers et envoie régulièrement un signal de vie au serveur, toutes les 30 secondes.

Pour illustrer le moteur de scoring : imaginons qu'un fichier soit renommé avec l'extension `.locked` — cette extension inhabituelle est un signal connu des ransomwares. Ce comportement ajoute 80 points au score de risque. Si en plus une note de rançon apparaît dans le même dossier, 55 points s'ajoutent. Le score atteint 135 — bien au-dessus du seuil critique de 100. En moins de cinq secondes, une alerte est générée et un incident de sécurité est ouvert dans la console. Le système attend ensuite la décision de l'opérateur.

→ **Côté analyste, voici ce que la console SOC offre.**

Diapo 17/22 — CONSOLE SOC

Venons-en maintenant à la console SOC — l'interface que l'opérateur utilise au quotidien pour surveiller, réagir et rendre des comptes.

La console regroupe vingt-trois pages organisées en quatre sections : supervision (accueil, tableau de bord, machine hôte locale), infrastructure (réseaux, hôtes découverts, agents), détection et réponse (alertes, incidents, événements, actions de protection, file d'approbation, simulateur), et configuration (utilisateurs, santé SOC, journal d'audit, rapports, webhooks, règles de détection, seuils d'analyse, politiques, paramètres, extensions sensibles).

Ce qui est fondamental dans RansomShield, c'est que chaque action proposée par le système passe obligatoirement par la file d'approbation. L'analyste l'approuve ou la rejette explicitement. Aucune action ne s'exécute en silence. Ce principe est non négociable.

Dès qu'une alerte est levée, l'opérateur est notifié simultanément par quatre canaux — sur l'interface web, par e-mail, par signal sonore et par webhook — pour s'assurer qu'aucune alerte ne passe inaperçue, quelle que soit sa situation.

↪ **Qu'est-ce que les tests ont donné ?**

Diapo 18/22 — TESTS & RÉSULTATS

Après la réalisation, venons-en aux tests et à la validation du système en conditions représentatives.

Une démarche en trois étapes complémentaires a été adoptée.

D'abord, cinq scénarios d'attaque représentatifs ont été définis, couvrant différents niveaux de complexité : du chiffrement simple à la chaîne d'attaque complète en 22 événements. Ces scénarios ont été construits à partir des comportements réels documentés dans la littérature.

Ensuite, un environnement de test réel sur trois machines virtuelles en réseau isolé a été mis en place, pour reproduire les conditions d'un vrai parc informatique, sans jamais déployer de malware réel.

Enfin, pour chaque scénario, trois indicateurs précis ont été mesurés : le délai de détection, l'intégrité des données transmises, et la complétude de la chaîne jusqu'à la décision de l'opérateur.

Les résultats sont constants : cinq scénarios exécutés, cinq détectés en moins de cinq secondes, zéro événement perdu. Notons honnêtement une limite : les tests ont été conduits sur Linux uniquement — c'est la première perspective d'évolution du projet.

↪ **Place maintenant à la démonstration live.**

Diapo 19/22 — DÉMONSTRATION LIVE — checklist 5 min, hors chrono

Suivre le guide de démonstration.

1. Console SOC ouverte : 3 agents en ligne
2. SSH sur `rs-client-1` : renommage `.locked` + note de rançon
3. Revenir sur la console : alerte critique apparue en moins de 5 secondes
4. **File d'approbation** : approuver l'action, montrer le rollback
5. **Timeline** : tout est horodaté
6. Simulation kill chain complète : 22 événements

↪ **Revenir à la présentation pour conclure.**

Diapo 21/22 — CONCLUSION & PERSPECTIVES

Nous voilà dans la cinquième et dernière partie de notre exposé.

Excellence Monsieur le Président du jury, Mesdames et Messieurs les membres du jury, permettez-nous de vous présenter la synthèse de ce travail.

RansomShield couvre l'intégralité du cycle de traitement d'un incident de sécurité : la détection sur le terminal, l'analyse comportementale, la génération de l'alerte, la décision de l'opérateur, et l'archivage complet de toutes les actions. Il est opérationnel, démontrable, et construit sans aucun malware réel.

Conscients que cette première implémentation, menée avec des ressources et un délai contraints, n'est pas exempte de lacunes : les tests ont été conduits sur Linux uniquement, et les communications restent en HTTP. Ce sont des limites assumées pleinement et nommées clairement.

Nous n'avons nullement la prétention d'avoir épuisé le sujet. C'est pourquoi nous comptons sur vos observations, vos critiques et vos recommandations pour enrichir ce travail. Chaque remarque du jury est pour nous une opportunité de progresser et de mieux faire.

Les perspectives sont tracées : sécuriser les communications pour la production, affiner les rôles selon le profil de chaque utilisateur, et doter le moteur d'un apprentissage automatique pour qu'il apprenne à reconnaître les comportements normaux et signale les anomalies avec encore plus de précision.

↪ **Nous restons à votre disposition pour vos questions.**

Diapo 22/22 — MERCI & QUESTIONS DU JURY — aide-mémoire

Dans un monde où les systèmes automatisent nos décisions, RansomShield rappelle une conviction simple : la machine peut détecter, mais c'est l'humain qui décide. Ce n'est pas une contrainte technique — c'est un choix éthique.

Merci pour votre aimable attention et pour le temps accordé à ce travail.

- **Python vs C/Go?** → Watchdog exploite inotify nativement — CPU minimal, portable Linux/Windows/macOS
- **Fausses alertes?** → Seuils configurables ; l'**opérateur humain** valide ou rejette avant toute action
- **Pourquoi pas HTTPS?** → LAN contrôlé ; chiffrement TLS = 1^{re} perspective pour la production
- **Différence avec un antivirus?** → L'antivirus reconnaît les empreintes ; RansomShield observe le comportement
- **Testé sur Windows?** → Non, limite assumée ; Linux uniquement ; extension Windows = 1^{re} priorité d'évolution

*Reformuler la question avant de répondre. Garder les **captures d'écran** prêtes.*